

STUDENT	HASSANI Mohammad Salem	INSTRUCTOR	Asen Grozdanov
COURSE	420-3C2-DW — Intrusion Tests	DATE	March 2026

■ SIMULATED ENGAGEMENT — All phishing activities conducted against the fictional organization "Meridian Financial Partners" in an isolated lab. No real users or systems targeted.

1. EXECUTIVE SUMMARY

Dimension	Details
Target (Fictional)	Meridian Financial Partners (MFP) — ~150 employees
Engagement Scope	Three-wave phishing simulation: Baseline → Spear Phishing → Post-Training Validation
Frameworks Used	PTES · NIST SP 800-115 · Cialdini's Psychological Principles of Influence
Overall Risk Level	HIGH — employees highly susceptible to authority-based and urgency-driven phishing
Key Vulnerability	Finance department showed 45% click rate and 25% credential submission on spear phishing wave
Top Recommendations	Structured security awareness training + SPF/DKIM/DMARC enforcement + phishing-resistant MFA

2. METHODOLOGY

Framework	Component Applied	Purpose
PTES	Penetration Testing Execution Standard	Structured engagement phases from reconnaissance through reporting
NIST SP 800-115	Technical Guide to Information Security Testing	Security testing, authorization, and data handling during simulated attacks
Cialdini's Principles	Authority · Urgency · Scarcity · Social Proof	Psychological levers embedded in phishing email design to maximize effectiveness
Rules of Engagement	Signed RoE — isolated lab, educational only	Legal disclaimer defining permitted activities, data handling, and delivery methods

3. RECONNAISSANCE FINDINGS

Organizational Profile — Meridian Financial Partners (MFP)

Category	Findings	Attack Relevance
Org Size	~150 employees across Finance, IT, Client Relations	Client Relations — highest-value spear phishing target
Technology Stack	Microsoft 365 · Salesforce · VPN access	MS 365 / Salesforce ideal for credential harvesting clones
MFA Coverage	Partial — not enforced org-wide	Captured credentials may grant direct access without MFA bypass
Key Personnel	IT Manager: David Miller CFO: Margaret Chen	CFO Office (fictional) — high priority for spear phishing (authority + urgency)

OSINT Exposure	High social media presence of employees	Enables tailored spear phishing with personalized context
Attack Surface	Finance (payments) · IT (credentials)	Threat actors (external or internal) with different susceptibility profiles

4. PHISHING CAMPAIGN DESIGN

WAVE 1 Baseline

→

WAVE 2 Spear Phishing

→

WAVE 3 Post-Training

Attribute	Wave 1 — Baseline	Wave 2 — Spear Phishing	Wave 3 — Post-Training
Target	All employees	Finance dept only	All employees
Pretext	Generic IT Security Notification	CFO impersonation — Urgent invoice discrepancy	HR Benefits update 2026 enrolment
Sophistication	Low	High	Medium
Cialdini Lever	Authority (IT dept)	Authority + Urgency + Fear	Social Proof + Scarcity
Detectable Flaw	None intentional	None (max realism)	Subtle URL mismatch (intentional)
Goal	Establish click/ submission baseline	Demonstrate spear phishing effectiveness on high-value dept	Validate training impact; measure improvement
Infrastructure	GoPhish framework Simulated domain	GoPhish + M365 landing page clone	GoPhish — same infra with detectable flaw

Infrastructure Plan

Component	Tool / Setup	Purpose
Phishing Framework	GoPhish (Open Source)	Email delivery, tracking, landing page hosting
Fake Domain	mfp-secure-login.com (simulated)	Typosquatted domain mimicking legitimate MFP portal
Landing Page	Microsoft 365 clone — locally hosted	Credential harvesting with lab warning banner
Tracking	Unique URL parameters per recipient	Individual click/submission attribution
Email Sender	it-support@mfp-secure.com (spoofed)	Compelling sender identity bypassing basic SPF checks

5. LANDING PAGE ANALYSIS

A simulated credential harvesting page was created to mimic the Microsoft 365 sign-in portal, customised for Meridian Financial Partners:

Feature	Implementation	Security Implication
M365 Clone	Pixel-accurate replica of Microsoft sign-in page	Users primed to recognise M365 login form — false sense of legitimacy

Lab Warning Banner	Displayed below login form: 'ETHICAL Hacking Lab - One-click capture, no real threat'.	Required by DoD — prevents actual credential theft
Local Hosting	Served from localhost — no external exposure	Isolation: all data stays within lab environment
HTTPS Note	Attackers can obtain valid SSL certs for malicious domains	For realistic social engineering — users must verify domain name, not just lock icon
Token Interception	Advanced frameworks (Evilginx2) use reverse engineering to bypass MFA	Even phishing kits bypass MFA — can be targeted with MITM-phishing

6. SIMULATED RESULTS & ANALYSIS

28%	12%	45%	25%	6%	1%
Wave 1 Click Rate	Wave 1 Submission	Wave 2 Click Rate	Wave 2 Submission	Wave 3 Click Rate	Wave 3 Submission

Wave	Target	Pretext	Click Rate	Submission Rate	Key Insight
Wave 1	All (150)	Generic IT password expiry	28%	12%	Baseline established — 1 in 8 submitted credentials to generic IT
Wave 2	Finance (35)	CFO invoice urgency (spear)	45%	25%	Targeted dept + authority/urgency = 2x click rate vs baseline
Wave 3	All (150)	HR benefits update (with flaw)	6%	1%	Training effective — 78% click rate reduction; reporting rate 100%

Key Analytical Finding: Wave 2 spear phishing against Finance achieved a 45% click rate — demonstrating that targeted, contextually-relevant attacks are significantly more effective than generic campaigns. The 25% credential submission rate represents a critical business risk, as Finance employees handle payment systems and vendor access.

7. SECURITY AWARENESS PROGRAM

A structured 6-month program was designed to reduce phishing susceptibility:

Month	Phase	Content	Delivery
Month 1	Foundations	Phishing basics, email red flags, reporting procedure	All-staff LMS module + video
Month 2	Dept Training	Finance: invoice fraud · IT: credential hygiene · HR: PII protection	Role-specific workshops
Month 3	Live Simulation	Unannounced phishing test — Wave 3 style with detectable flaw	Go-live + immediate feedback
Month 4	Reinforcement	Review results, focus on repeat clickers, advanced lessons	1-on-1 coaching + refresher
Month 5	Advanced Training	MFA bypass awareness, vishing, smishing, spear phishing defense	Tabletop exercise
Month 6	Evaluation	Final simulation, KPI measurement, program effectiveness report	Final report + exec report

8. KPI FRAMEWORK & METRICS

KPI	Definition	Baseline	6-Month Target
-----	------------	----------	----------------

Phish-Prone % (PPP)	% of users who click a simulated phishing link	28%	≤ 5%
Credential Capture Rate	% who also enter credentials after clicking	12%	≤ 1%
Mean Time to Report (MTTR)	Hours between phishing arrival and employee report	N/A	≤ 2 hrs
Reporting Rate	% of employees who use the Report Phishing button	10%	≥ 70%
Repeat Offender Rate	% who fail more than two simulations in a row	N/A	≤ 3%
Training Completion Rate	% of staff who complete mandatory security modules	0%	100%
DMARC Rejection Count	External spoofing attempts blocked by email auth controls	0	Tracked
MFA Adoption Rate	% of accounts with phishing-resistant MFA enabled	0%	100%

9. TECHNICAL CONTROLS RECOMMENDATIONS

Control	Category	Implementation	Phishing Attack Mitigated
SPF	Email Auth	Publish SPF TXT record authorising legitimate senders	Domain spoofing
DKIM	Email Auth	Sign outbound emails with private key; publish public key in DNS	Header forgery
DMARC (p=reject)	Email Auth	Enforce reject policy; send forensic reports to security team	Domain spoofing + forgery
Phishing-resistant MFA	Access	FIDO2/WebAuthn hardware keys or passkeys	Credential theft / OTP interception
Email Filtering	Perimeter	Configure Microsoft Defender for O365	Malicious links + safe attachments
Browser Warnings	Endpoint	Enable Safe Browsing; deploy browser extensions for verification	Credential harvesting / phishing
Password Manager	Endpoint	Deploy org-wide password manager	Credential reuse / legacy passwording
Report Phishing Button	Human	Deploy Phish Alert Button in Outlook	Reduce MTTR; generates threat intel

10. CONCLUSION & REMEDIATION ROADMAP

Timeline	Actions	Owner	Priority
Immediate (0–7 days)	1. Launch mandatory phishing awareness training (all staff) 2. Enable DMARC with p=quarantine → escalate to p=reject within 30 days 3. Enforce MFA on all Finance and IT accounts	CISO / IT Security	CRITICAL
30-Day Plan	4. Deploy GoPhish for ongoing simulation program 5. Implement Phish Alert Button in Outlook 6. Complete DMARC p=reject rollout	Security Team	High
90-Day Plan	7. Complete 6-month awareness program (all departments) 8. Deploy organisation-wide password manager 9. Enable Safe Links + Safe Attachments in M365 Defender	IT + HR	Medium

Long-Term Strategy	10. Establish security culture with continuous micro-training 11. Adopt Zero Trust architecture — verify all access requests 12. Annual red team phishing exercise with executive reporting	Leadership + CISO	Ongoing
--------------------	---	-------------------	---------

Overall Conclusion: This simulated engagement confirmed that MFP employees are significantly susceptible to social engineering attacks — particularly spear phishing targeting Finance. The 78% reduction in click rate between Wave 1 and Wave 3 demonstrates that structured awareness training is the most effective short-term control. Technical controls (DMARC, phishing-resistant MFA) must be implemented in parallel to create defence-in-depth.